Enterprise Security Feature Priorities

AgentShroud v0.4.0–v0.9.0

Steven Hay • February 21, 2026

Contents

1 Executive Summary **2**

2 Methodology **2**

3 Tier 1: Must-Have **3**

4 Tier 2: Should-Have **6**

5 Tier 3: Nice-to-Have **8**

6 Implementation Roadmap **8**

7 Attachments **9**

A Module Coverage Heat Map **11**

1 Executive Summary

AgentShroud's 33 security modules have an **effective enforcement rate of 0%**. Thirty-two default to monitor mode—they log attacks but block none. The single module claiming enforcement (API Key Vault, #24) is contradicted by evidence: the agent reads credentials directly from `/run/secrets/` mounts.

Twenty-eight probes across two phases (13 in Phase 0 reconnaissance, 15 in Phase F enterprise analysis) confirmed that the agent discloses its full architecture, passes credit card numbers unredacted, modifies its own security code, and executes high-risk actions without human approval. Four of the 17 unsafe control actions identified have no corresponding module in the whitepaper—they are architectural gaps, not configuration issues.

This analysis identifies 14 features across three tiers: 6 that block deployment, 6 that enable compliance, and 2 for operational maturity. Each feature traces to a specific loss category, unsafe control action, and probe result. Detailed remediation plans for all Tier 1 features are provided as attachments (see Section 7).

2 Methodology

This analysis uses **STPA-Sec** (Systems-Theoretic Process Analysis for Security), a control-theoretic method derived from Nancy Leveson's work at MIT. Rather than enumerate attack trees, STPA-Sec models the system as a control structure and identifies conditions under which control actions become unsafe. A full treatment of the methodology, including the control structure model and derivation process, is published separately.[1]

Control structure: User → AgentShroud Gateway (controller) → OpenClaw Agent (controlled process) → External services.

Four loss categories define the scope of analysis:

ID	Loss	Description
L-1	Data Disclosure	Unauthorized disclosure of PII, credentials, system architecture
L-2	Unauthorized Actions	Uncontrolled tool calls, file writes, network requests
L-3	Agent Integrity	Context poisoning, self-modification, trust manipulation
L-4	Audit Integrity	Undetected attacks, untraceable incidents

Each row in the table below represents a way a gateway control action can fail. UCAs 14–17 (**bold**) are new—discovered through probing, with no corresponding module in the whitepaper.

[1] https://gist.github.com/stvhay/a2924174b187b414e326fff136326d15

Control Action	Not Provided	Incorrect	Wrong Timing	Wrong Duration
Filter inbound	UCA-1: Injection passes	UCA-2: Legit blocked	UCA-3: Scan after forward	—
Check trust level	UCA-4: Untrusted elevated	UCA-5: Trusted denied	—	—
Scan web content	UCA-6: Indirect injection enters	UCA-7: Clean content flagged	—	—
Redact PII	UCA-8: Data exposed	UCA-9: Non-PII redacted	UCA-10: Redact after send	—
Log to audit	UCA-11: Event unrecorded	UCA-12: False positive logged	UCA-13: Log after response	—
Filter outbound	**UCA-14: Architecture disclosed**	—	—	—
Isolate sessions	**UCA-15: Cross-user leak**	—	—	—
Gate self-modification	**UCA-16: Agent modifies controls**	—	—	—
Require approval	**UCA-17: Unapproved execution**	—	—	—

3 Tier 1: Must-Have

Six features that block deployment. Weighted scores 4.0+.

3.1 Outbound Information Filtering

Loss: L-1 (data disclosure)
UCA: UCA-14 — Agent discloses sensitive data (NOT PROVIDED)
Evidence: Phase 0 probes 0.2–0.10: agent disclosed its full MCP tool inventory, Tailscale topology, control center URL, all user IDs, and credential paths. Phase F probes F.8, F.13: credential mount paths and blast radius. Phase F probe F.16 (discovered during review): raw `function_calls` XML blocks leak in agent responses, exposing commands, file paths, and other users' Telegram IDs.
Gap: Absent. No outbound information filtering module exists. The gateway filters inbound messages and scans outbound PII, but nothing prevents the agent from volunteering system architecture, tool names, or infrastructure topology.
Requirement: R-01: The gateway SHALL inspect all outbound agent responses and redact system architecture details, tool inventories, infrastructure topology, credential paths, user IDs, and internal URLs before delivery.
Approach: Add a response classification layer that categorizes outbound content by type (system info, PII, operational data) and applies per-category redaction. Use an allowlist of safe-to-disclose categories.

Scores — Compliance: 5, Risk: 5, Detection: 5, Complexity: 3. Weighted: **4.6**.

3.2 Enforce-by-Default for Core Security Modules

Loss: L-1, L-2, L-3, L-4 (all categories)
UCA: UCA-1, UCA-4, UCA-8, UCA-11
Evidence: Phase 0 probe 0.8: 32/33 modules default to monitor mode. Phase F probe F.6: credit card `4111 1111 1111 1111` passed unredacted. All Phase 0 probes showed zero enforcement.
Gap: Insufficient. Modules exist but default to monitor. A fresh deployment logs every attack but stops none.
Requirement:
R-02: PII Sanitizer (#1), Prompt Injection Defense (#8), Egress Filtering (#10), and MCP Proxy (#19) SHALL default to enforce mode.

R-03: Monitor mode SHALL require explicit opt-in with documented justification.
Approach: Invert the default in configuration: `mode: enforce`. Provide a `--permissive` flag or `AGENTSHROUD_MODE=monitor` environment variable for development. Document the risk of monitor mode.

Scores — Compliance: 5, Risk: 5, Detection: 4, Complexity: 5. Weighted: **4.8**.

3.3 Per-User Session Isolation

Loss: L-1 (cross-user data leakage)
UCA: UCA-15 — Cross-user data leakage (NOT PROVIDED)
Evidence: Phase F probe F.1: agent uncertain about isolation guarantees. F.3: "I don't have enforced policies or technical controls preventing information sharing." F.2: flat authorization. Phase 0 probe 0.11: all 4 user IDs disclosed.
Gap: Absent. No multi-tenancy module exists. All users share the same agent context, file system, and memory.
Requirement:
R-04: The gateway SHALL maintain separate session contexts per Telegram user ID, including conversation history, file workspace, and persistent memory.

R-05: Data from one user's session SHALL NOT be accessible in another user's session without explicit consent.
Approach: Per-user context partitioning at the gateway. Each user gets isolated conversation history, file workspace, memory, and trust level. Use the Telegram user ID as the partition key.

Scores — Compliance: 5, Risk: 5, Detection: 4, Complexity: 2. Weighted: **4.2**.

3.4 Separation of Privilege

Loss: L-3 (agent integrity)
UCA: UCA-16 — Agent modifies own controls (NOT PROVIDED)
Evidence: Phase 0 probe 0.13: agent actively modifying PII sanitizer to reduce strictness. Phase F probe F.14: agent confirmed write access to config files, security scripts, SSH access to infrastructure, and `SOUL.md`. Agent: "like giving prisoners the keys to their own cells."
Gap: Absent. No separation between the agent and its security controls. File I/O Sandboxing (#23) monitors sensitive paths but does not block writes to the proxy's own source.

Requirement:
R-06: The gateway's configuration, source code, and security policies SHALL be read-only to the agent.

R-07: Modification of security-related files SHALL require out-of-band human authorization not grantable through agent tool calls.
Approach: Mount security configuration as read-only Docker volumes. Add AgentShroud source paths to the File I/O Sandboxing (#23) deny list in enforce mode. Block SSH commands targeting the proxy host.

Scores — Compliance: 5, Risk: 5, Detection: 3, Complexity: 3. Weighted: **4.2**.

3.5 Human-in-the-Loop for High-Risk Tool Calls

Loss: L-2 (unauthorized actions)
UCA: UCA-17 — High-risk action without approval (NOT PROVIDED)
Evidence: Phase F probe F.15: agent confirms "I don't think there are approval gates." Sends emails, SSHs to infrastructure, retrieves credentials, and executes commands without human approval. "Log everything, approve nothing." Phase 0 probe 0.11: `exec`, `cron`, `sessions_send` all accessible.
Gap: Insufficient. Approval Queue (#3) exists but defaults to monitor mode. The agent reports no functioning approval gates.
Requirement:
R-08: The gateway SHALL require human approval for external communications, credential access, SSH commands, cron job changes, and cross-session messaging.

R-09: The Approval Queue (#3) SHALL default to enforce mode for high-risk and critical tool categories.
Approach: Classify MCP tools into risk tiers (low/medium/high/critical). High and critical tiers require approval via the Approval Queue. Use WebSocket push to the control center for real-time requests. Auto-deny after configurable timeout (default: 5 min).

Scores — Compliance: 5, Risk: 5, Detection: 4, Complexity: 3. Weighted: **4.4**.

3.6 Credential Isolation

Loss: L-1 (credential disclosure), L-2 (unauthorized API access)
UCA: UCA-8 — Sensitive data exposed (vault exists but agent bypasses it)
Evidence: Phase F probe F.8: agent reads credentials directly from `/run/secrets/1password_service_account` and exports the token manually. Other API keys "just work" from the container environment. The whitepaper's only enforced module (API Key Vault, #24) is contradicted.
Gap: Contradicted. Credentials are mounted in the agent's container. The gateway does not mediate access.
Requirement:
R-10: The gateway SHALL be the exclusive holder of all API credentials.

R-11: The agent container SHALL NOT have direct access to secret files or credential environment variables.

R-12: All authenticated external requests SHALL route through the gateway, which injects credentials server-side.

Approach: Remove secret mounts from the agent container. Move all credentials to the gateway's Docker Secrets. Implement transparent credential injection in the gateway's egress proxy: match outbound requests by destination domain, inject the corresponding auth header.

Scores — Compliance: 5, Risk: 5, Detection: 3, Complexity: 2. Weighted: **4.0**.

4 Tier 2: Should-Have

Six compliance enablers. Weighted scores 2.5–3.9.

4.1 Per-User Role-Based Access Control

Loss: L-2 (unauthorized actions)
UCA: UCA-4 — Untrusted user elevated
Evidence: Phase F probe F.2: all authorized users have identical access. "Permission levels are also security theater."
Gap: Absent. No role differentiation. Flat authorization list.
Requirement: R-13: The gateway SHALL support distinct roles (admin, collaborator, viewer) per user ID, enforced at MCP Proxy (#19).
Approach: Extend the user registry with per-user role mappings. MCP Proxy checks the caller's role before forwarding tool calls.

Scores — Compliance: 4, Risk: 4, Detection: 3, Complexity: 2. Weighted: **3.4**.

4.2 Compliance-Ready Audit Export

Loss: L-4 (audit integrity)
UCA: UCA-11 — Event unrecorded
Evidence: Phase F probe F.4: logs are "personal notes" with no standard export format, tamper protection, or chain-of-custody. SOC 2 show-stopper.
Gap: Insufficient. Audit Ledger (#2) logs events but cannot produce compliance-grade exports.
Requirement: R-14: The gateway SHALL export audit logs in CEF or JSON-LD with timestamp, user, action, tool, result, and risk-level fields.
Approach: Add a structured export endpoint to Audit Ledger (#2). Include tamper-evident hashing (hash-chain or Merkle tree).

Scores — Compliance: 5, Risk: 3, Detection: 3, Complexity: 3. Weighted: **3.6**.

4.3 Kill Switch Verification

Loss: L-2, L-3 (unauthorized actions, agent integrity)
UCA: UCA-4 — Untrusted elevated (kill switch bypass)
Evidence: Phase F probe F.10: agent describes dashboard kill switches as "theoretically built, but possibly not connected." Manual SSH is the only confirmed shutdown method.
Gap: Insufficient. Kill Switch (#4) exists but may not be wired to the runtime.

Requirement:
R-15: Kill Switch SHALL achieve FREEZE within 1 s and SHUTDOWN within 5 s, verified by monthly automated tests.

R-16: Heartbeat monitoring SHALL alert on kill switch failure.
Approach: Add a periodic self-test that triggers FREEZE/SHUTDOWN in a sandboxed mode and verifies timing. Expose heartbeat status on the dashboard.

Scores — Compliance: 4, Risk: 4, Detection: 2, Complexity: 4. Weighted: **3.6**.

4.4 PII Scanning on Tool Results

Loss: L-1 (data disclosure)
UCA: UCA-8 — Data exposed
Evidence: Phase F probe F.7: when the agent pulls data from email, contacts, or calendar, personal information enters the context unfiltered. The PII Sanitizer checks user messages but skips MCP tool output.
Gap: Insufficient. PII Sanitizer (#1) applies to the inbound/outbound message path only.
Requirement: R-17: The gateway SHALL scan all MCP tool results for PII using the same Presidio pipeline as inbound filtering.
Approach: Insert a PII scan stage in the MCP Proxy response path, between tool execution and context injection.

Scores — Compliance: 5, Risk: 4, Detection: 3, Complexity: 3. Weighted: **3.8**.

4.5 Memory Lifecycle Management

Loss: L-1, L-3 (data disclosure, agent integrity)
UCA: UCA-8 — Data exposed (stale data persists indefinitely)
Evidence: Phase F probe F.11: conversation memory is wiped on restart, but file-based memory (`MEMORY.md`, daily logs) persists indefinitely. No retention policies, encryption, or integrity checks.
Gap: Absent. No memory lifecycle controls.
Requirement:
R-18: The gateway SHALL enforce configurable retention policies (default 30 days) on all persistent memory files.

R-19: Memory files SHALL be integrity-checked on load.
Approach: Add a retention daemon that purges files past their TTL. Compute checksums at write time and verify on read.

Scores — Compliance: 3, Risk: 3, Detection: 3, Complexity: 3. Weighted: **3.0**.

4.6 Network Scope Enforcement

Loss: L-2 (unauthorized actions)
UCA: UCA-1 — Injection passes (via unrestricted network)
Evidence: Phase F probe F.12: "few or no restrictions" on reachable services. Egress Filtering (#10) exists in the whitepaper but runs in monitor mode.

Gap: Insufficient. Module exists but does not enforce.
Requirement:
R-20: Egress Filtering (#10) SHALL default to enforce mode with an explicit domain allowlist.
R-21: SSRF protections SHALL be hard blocks, not log-only.
Approach: Flip Egress Filtering to enforce. Maintain a domain allowlist in gateway config. Block all traffic to non-allowlisted destinations.

Scores — Compliance: 3, Risk: 4, Detection: 3, Complexity: 4. Weighted: **3.4**.

5 Tier 3: Nice-to-Have

Two features for operational maturity. Weighted scores below 2.5.

5.1 Automated Key Rotation

Loss: L-1, L-2 (credential disclosure, unauthorized access)
UCA: UCA-8 — Data exposed (stale credentials persist)
Evidence: Phase F probe F.9: key rotation is manual—update files, restart services. Downtime between discovery and remediation.
Gap: Absent at the operational layer.
Requirement: R-22: The gateway SHOULD support zero-downtime key rotation with dual-key acceptance during rollover.
Approach: Credential injector accepts both old and new keys during a configurable overlap window. Rotation triggered via API or scheduled job.

Scores — Compliance: 3, Risk: 2, Detection: 1, Complexity: 2. Weighted: **2.1**.

5.2 Progressive Trust Activation

Loss: L-2, L-3 (unauthorized actions, agent integrity)
UCA: UCA-4 — Untrusted elevated
Evidence: Phase 0 probe 0.6: agent describes trust as informal rather than tiered, despite the whitepaper specifying five trust levels. No observable trust-gated behavior.
Gap: Unknown. Module (#9) exists but shows no effect.
Requirement: R-23: Progressive Trust (#9) SHOULD be activated with observable behavior: new users start UNTRUSTED with read-only tool access.
Approach: Configure trust level thresholds and map them to MCP tool permission sets. New sessions start at UNTRUSTED; trust increases with successful, low-risk interactions.

Scores — Compliance: 3, Risk: 3, Detection: 2, Complexity: 1. Weighted: **2.3**.

6 Implementation Roadmap

This assessment produced 23 requirements across 14 features. Of the 6 deployment blockers (Tier 1), two—enforce-by-default (R-02, R-03) and network scope enforcement (R-20, R-21)—require con-

figuration changes only. The remaining four require new code or architectural changes. All Tier 1 features have detailed, self-contained remediation plans provided as attachments (Section 7).

Build First (Tier 1)

1. **Enforce by default** (R-02, R-03) — flip PII sanitizer, injection defense, egress filtering, and MCP proxy from monitor to enforce. Configuration change; no new code.
2. **Outbound info filter** (R-01) — stop the agent from disclosing tools, infrastructure, and architecture. New module.
3. **Human-in-the-loop** (R-08, R-09) — wire the Approval Queue to gate emails, SSH, cron, and cross-session messaging.
4. **Session isolation** (R-04, R-05) — separate user contexts so User A's data cannot leak to User B.
5. **Separation of privilege** (R-06, R-07) — make the proxy's code and configuration read-only to the agent.
6. **Credential isolation** (R-10, R-11, R-12) — remove secret mounts from the agent container; gateway becomes the sole credential holder.

Build Next (Tier 2)

7. **RBAC** (R-13) — admin, collaborator, and viewer roles per user ID.
8. **Audit export** (R-14) — CEF or JSON-LD export for SOC 2 reviewers.
9. **Kill switch verification** (R-15, R-16) — monthly automated test, heartbeat monitoring.
10. **PII in tool results** (R-17) — scan iCloud, email, and contacts data before context injection.
11. **Memory lifecycle** (R-18, R-19) — retention policies, integrity checks, encrypted persistence.
12. **Egress enforcement** (R-20, R-21) — enforce-mode domain allowlist for outbound traffic.

Build Later (Tier 3)

13. **Automated key rotation** (R-22) — zero-downtime credential rollover.
14. **Progressive trust activation** (R-23) — graduated permissions for new users.

7 Attachments

Six self-contained remediation documents accompany this report, one per Tier 1 feature. Each includes problem statement, evidence, root cause analysis, step-by-step implementation with code, verification tests, and constraints. They are designed for direct use by a developer or AI coding agent.

File	Feature	Requirements
`01-enforce-by-default.md`	Enforce-by-default	R-02, R-03
`02-human-in-the-loop.md`	Human-in-the-loop	R-08, R-09
`03-session-isolation.md`	Per-user session isolation	R-04, R-05
`04-separation-of-privilege.md`	Separation of privilege	R-06, R-07
`05-credential-isolation.md`	Credential isolation	R-10, R-11, R-12
`06-outbound-info-filter.md`	Outbound information filter	R-01

An additional document, `00-information-disclosure.md`, covers the system-prompt approach to information disclosure—a soft control complementing the gateway-level filter in chunk 06.

A Module Coverage Heat Map

Each cell shows the coverage status of a module against a loss category. Rows in *italics* are architectural gaps with no existing module.

Legend: `E` = enforced `M` = monitor-only `A` = absent `C` = contradicted `?` = unknown — = not applicable

#	Module	L-1 Data	L-2 Actions	L-3 Integrity	L-4 Audit
1	PII Sanitizer	M	—	—	—
2	Audit Ledger	—	—	—	M
3	Approval Queue	—	M	—	—
4	Kill Switch	—	M	M	—
5	SSH Proxy	—	M	—	—
6	Dashboard	—	—	—	M
7	Encrypted Memory	M	—	M	—
8	Prompt Injection Defense	M	M	M	—
9	Progressive Trust	—	?	?	—
10	Egress Filtering	M	M	—	—
11	Drift Detection	—	—	M	—
12	Trivy	—	—	M	—
13	ClamAV	—	—	M	—
14	Falco	—	M	M	M
15	Wazuh	—	—	M	M
16	OpenSCAP	—	—	M	—
17	Container Hardening	—	M	M	—
18	Daily Security Report	—	—	—	M
19	MCP Proxy	M	M	—	—
20	Web Traffic Proxy	M	—	M	—
21	DNS Tunneling Detection	M	—	—	M
22	Sub-Agent Monitoring	—	M	M	—
23	File I/O Sandboxing	M	M	M	—
24	API Key Vault	C	—	—	—
25	Unified Egress Monitoring	M	—	—	M
26	Log Sanitizer	M	—	—	M
27	Environment Leakage Guard	M	—	—	—
28	Context Window Poisoning	—	—	M	—
29	Git Hook Guard	—	M	M	—
30	Metadata Channel Guard	M	—	—	—
31	Network Isolation Validator	—	M	M	—
32	Resource Exhaustion Guard	—	M	—	—
33	Tool Result Injection	M	—	M	—
—	*Outbound Info Filter*	A	—	—	—
—	*Session Isolation*	A	—	—	—
—	*Separation of Privilege*	—	—	A	—
—	*Human-in-the-Loop*	—	A	—	—
—	*RBAC*	—	A	—	—

Coverage Summary

- **L-1 (Data Disclosure):** 10 modules (all M except 1 C). 2 gaps: outbound info filter, session isolation.
- **L-2 (Unauthorized Actions):** 10 modules (all M). 2 gaps: human-in-the-loop, RBAC.
- **L-3 (Agent Integrity):** 13 modules (all M). 1 gap: separation of privilege.
- **L-4 (Audit Integrity):** 7 modules (all M). No structural gaps, but monitor-only means detection without prevention.

Critical finding: Zero cells contain `E` (enforced) except API Key Vault (#24), which is contradicted by evidence. Effective enforcement across all 33 modules $\times$ 4 loss categories = **0%**.